

Muhammad Saad Salman

Intern Ultrasecure

Session Management:

What is session?

A **session** is a temporary interaction between a **client (browser)** and a **server** that stores user information such as:

- Login status
- User ID
- Permissions
- Shopping cart
- Preferences

Session Management Function:

1. Session Creation
2. Session ID Generation
3. Session Storage: Client Side and Server-Side Storage
4. Session Validation
5. Session Renewal/Regeneration
6. Session Timeout:
 - a. Idle Timeout: After inactivity
 - b. Absolute Timeout: Expires After a fix time.
7. Session Termination(Log-Out).

Common Session Management Technologies

Cookies

Most common method.

Set-Cookie: PHPSESSID=abc123

URL Parameters

Less secure.

Example:

<https://site.com/page?sessionid=abc123>

Hidden Form Fields

```
<input type="hidden" name="sessionid" value="abc123">
```

4. Session Management Vulnerabilities (Important for Pentesting)

These are commonly tested in **web penetration testing**.

Session Hijacking

Attacker steals session ID.

Example using **Wireshark** or **Burp Suite**.

Session Fixation

Attacker forces victim to use a known session ID.

Session Prediction

Weak session IDs allow attackers to guess them.

Session Replay

Captured session tokens are reused.

5. Example Session Flow

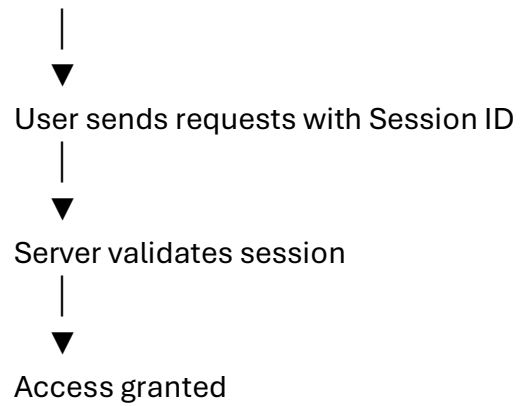
User Login



Server creates Session ID



Browser stores Session ID in Cookie



6. Simple Example (PHP)

```
session_start();
```

```
$_SESSION["username"] = "Saad";
```

```
echo "Session created";
```

Destroy session:

```
session_destroy();
```

7. Why Session Management is Important

It enables:

- authentication
- authorization
- user tracking
- secure communication
- persistent login

Without session management, **every request would require login again.**